

AGENTIC GUARDRAILS

Before You Give an AI Agent the Keys

AI agents are moving from answering questions to taking action - editing files, updating records, sending messages, using tools, and carrying work across multiple steps. That creates capacity, but it also creates an authority question: what may the agent do, what requires approval, and how will you know what happened afterward?

WHY THIS MATTERS NOW

- **Agents are gaining real operating authority.** OpenAI describes workspace agents that can edit documents, update records, send messages, and run recurring workflows with permissions, approval checkpoints, monitoring, and audit logs.
- **Approval prompts alone are not enough.** Anthropic reports users approved about 93% of Claude Code permission prompts; stronger sandbox boundaries later reduced prompts by 84%.
- **Adoption is outrunning operating readiness.** NTEN and The Bridgespan Group surveyed 917 nonprofit staff and executives in 2026; reporting on the study found 98% used AI in some capacity, while only 4% described it as fully integrated.

THE FIVE GUARDRAILS

1. Define the agent's authority

Write down what the agent may do independently, what it may prepare but not execute, and what it must never do.

Authority should be designed, not assumed.

2. If permission matters, specify it

For sending, spending, publishing, deleting, changing records, or sensitive data, avoid vague instructions such as "handle this."

Ambiguity can become unintended authority.

3. Keep the human decision point

Choose consequential actions that require human approval - without creating so many prompts that people stop paying attention.

Protect judgment without approval fatigue.

4. Access is not governance

Connection to email, Drive, Slack, finance tools, or a CRM only defines reach. Governance defines scope, allowed actions, review points, and escalation.

Give the agent only what it needs.

5. Make the work reconstructable

Keep enough operating evidence to understand who initiated the task, what the agent accessed, what changed, what was approved, and how exceptions were corrected.

No trace, no meaningful oversight.

A PRACTICAL FIELD GUIDE

Five questions before you deploy an agent

- ✓ What can this agent see?
- ✓ What can it change, send, publish, spend, or delete?
- ✓ Which actions require explicit human approval?
- ✓ What happens when instructions are ambiguous or the agent is unsure?
- ✓ If something goes wrong, can we trace what happened and recover?

THE FIELD OF PLAY

Apply the same discipline anywhere an agent can create a real-world side effect: communications, finance, HR, donor or customer records, calendars, files, publishing, procurement, research, data movement, and connected applications. The more consequential the action, the clearer the permission and recovery path should be.

VERIFY THE GUIDANCE

OpenAI - Guardrails and human review

Human review can pause sensitive side effects such as edits, shell commands, cancellations, or sensitive tool actions.

OpenAI - Workspace agents for business

Role-based access, audit logs, monitoring, and approval gates are part of the governance model.

Anthropic - How we contain Claude across products

Explains permission fatigue, sandboxing, access boundaries, and limiting an agent's potential blast radius.

NTEN + The Bridgespan Group - State of Nonprofit AI

Benchmarks AI adoption, governance, leadership, and training across 917 nonprofit staff and executives.

Guardrails are not about slowing agents down.

They make delegation deliberate, visible, and trustworthy.

Cardwell Communications | Organizational Intelligence + Executive AI Training

Practical guidance for responsible, useful AI adoption.

Operational guidance only. Apply legal, privacy, security, and sector-specific requirements appropriate to your organization.